



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-6253 proxy credentials leak over redirect-to proxy

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-14
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-6253 proxy credentials leak over redirect-to proxy - Vulnerability Report

Published: 2026-06-14 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-6253 is a curl and libcurl credential-disclosure flaw that can leak proxy credentials across a redirect-driven proxy change. Public vendor and downstream tracking reviewed for this report agree on the core trigger: curl is configured to use different proxies for different URL schemes, the first proxy requires credentials, the second proxy does not, and a redirect causes curl to switch from the first proxy context to the second. Under that sequence, credentials intended for the original proxy can be forwarded to the second proxy instead.

The weakness is operationally important because the affected surface is broader than direct human use of the `curl` CLI. libcurl is embedded in automation, package retrieval, CI/CD jobs, orchestration tooling, update agents, backup software, data movers, and bespoke applications. Teams may correctly protect one outbound path with an authenticated enterprise proxy while also using a separate non-authenticated proxy for another scheme or destination class; a malicious or compromised redirecting server can then abuse that trust split to expose credentials to infrastructure under different administrative control.

This is not a generic remote code execution or host-compromise issue. The practical impact is unauthorized disclosure of proxy credentials, which can in turn support access to monitored egress infrastructure, logging blind spots, or follow-on abuse of proxy-backed trust relationships. Exposure is highest where organizations use scheme-specific proxy settings, permit redirects from untrusted content sources, and rely on reusable service-account proxy credentials in unattended workflows.

The primary defensive action is to upgrade curl/libcurl to 8.20.0 or to vendor-backported packages that remediate the flaw, then identify workflows that combine redirects with multiple proxy definitions. Detection and hunting should focus on inventorying curl/libcurl dependencies, finding process executions that use redirects plus proxy settings, and identifying egress patterns where the same process reaches multiple proxies or proxy-auth paths in close succession. Public tracking reviewed for this report did not provide authoritative evidence of widespread in-the-wild exploitation or CISA KEV inclusion at assessment time, so urgency should be driven by exposure and credential sensitivity rather than by hype alone.

2. Intelligence Requirement

This report addresses the following intelligence requirement: what does CVE-2026-6253 mean for defenders using curl or libcurl in proxied workflows, which environments are materially exposed, how likely is opportunistic abuse, and what remediation, detection, and hunting actions should be prioritized immediately?

Question	Assessment
What is the flaw?	curl/libcurl can leak credentials for one proxy to a different proxy after a redirect-triggered proxy change.
What preconditions matter?	Different proxies must be configured for different URL schemes, the first proxy must require credentials, the second must not, and a redirect must move the request into the second proxy context.
What is the primary impact?	Credential disclosure to an unintended proxy under separate administrative control.
Which products are affected?	curl and libcurl deployments using affected proxy and redirect logic, including embedded library use inside applications and automation.
Which versions are affected?	Public curl advisory tracking identifies affected versions from 7.14.1 through 8.19.0 inclusive.
What is the fixed version?	curl/libcurl 8.20.0, or vendor backports carrying the same remediation.
Is exploitation broadly confirmed?	Reviewed public sources did not provide authoritative evidence of broad in-the-wild exploitation or KEV inclusion at assessment time.

Which environments deserve highest priority?	CI/CD, package distribution, artifact download, cloud bootstrap, and enterprise automation workflows that use authenticated outbound proxies and follow redirects from less-trusted sources.
--	--

3. Source Review and Confidence

Source	Contribution	Confidence
curl security advisory (CVE-2026-6253.html)	Canonical flaw description, trigger conditions, affected version range, remediation version, and vendor severity	High
curl machine-readable advisory JSON / OSV summary	Structured confirmation of publication timing, affected range, and fixed-commit metadata surfaced by public vulnerability trackers	High
NVD CVE record	Public enrichment and reference consolidation used to normalize severity and ecosystem tracking	High
Debian Security Tracker	Downstream package-status context and backport caveats for Linux estate triage	High
Openwall oss-security republication	Independent republication and disclosure-timeline corroboration	High
OpenCVE / public aggregation	Additional context on KEV absence, low EPSS reporting, and weakness labeling caveats	Medium

Confidence is high for the core technical assessment because multiple independent public sources align on the same trigger sequence, affected versions, and fixed release. Confidence is medium for exploitation prevalence because the reviewed source set did not include a vendor statement of active exploitation, a CISA KEV listing, or detailed incident-response case studies showing widespread operational abuse.

Two caveats matter for defenders. First, this flaw is heavily workflow-dependent: environments that do not use distinct proxies for different URL schemes, or that do not follow redirects from untrusted sources, are materially less exposed than environments that do. Second, version strings alone are not always definitive for Linux and appliance triage because downstream vendors may ship backports without matching upstream 8.20.0 naming exactly; package-manager and vendor-advisory validation should supplement simple semver checks.

4.1 Vulnerability metadata

Field	Value
CVE	CVE-2026-6253
Product family	curl and libcurl
Vulnerability class	Cross-proxy credential disclosure during redirect-driven proxy reassignment
Primary weakness	CWE-522 Insufficiently Protected Credentials
Vendor severity	Medium
Public severity normalization	Multiple public trackers summarize the issue as medium severity;

	some downstream vendors label it Moderate
Affected versions	curl/libcurl 7.14.1 through 8.19.0 inclusive
Fixed version	curl/libcurl 8.20.0
Introduced by	Public tracking indicates the flaw dates back to the addition of credentials in proxy strings, traced to curl 7.14.1-era behavior
Fixed commit	Public OSV and downstream tracker references point to curl commit `188c2f166a20fa97c2325b2da7d0e5cecc13725f`
Public disclosure	2026-04-29 vendor advisory publication
Exploitation status	No authoritative broad in-the-wild exploitation confirmation identified during this review

4.2 Flaw mechanics

The vulnerability is not a generic “proxy auth leaks everywhere” condition. Public curl advisory text describes a narrow but realistic sequence of events:

- curl is configured to use different proxies for different URL schemes.
- The first proxy requires credentials.
- The second proxy does not require credentials.
- While using the first proxy, the client follows a redirect that causes it to use the second proxy.

When that sequence occurs, credentials associated with the first proxy can be sent to the second proxy. That makes the flaw especially relevant where redirect-following is routine and proxy boundaries reflect different trust zones, business partners, or administrative domains.

4.3 Exposure profile

Exposure pattern	Why it matters	Priority
Build pipelines and automation using authenticated outbound proxies plus `-L` / redirect-following behavior	Attackers controlling a redirecting endpoint can pivot requests into a different proxy context and capture enterprise proxy credentials	Immediate
Package managers, artifact downloaders, or bootstrap tooling embedding libcurl	libcurl use is often invisible to platform owners, making exposure easy to miss	Immediate
Separate proxy definitions for `http://` and `https://`, or per-scheme environment variables (`http_proxy`, `https_proxy`, `ALL_PROXY`)	Matches the vendor-described precondition for cross-proxy credential leakage	High
Service accounts using reusable proxy credentials in unattended workflows	Credential exposure can persist beyond a single failed request and affect shared infrastructure trust	High
Appliances or middleware with vendor-backported curl packages	Version-only scanning may misclassify real exposure or remediation state	Medium
Single-proxy estates with strict no-redirect or no-external-redirect controls	The described trigger sequence becomes much harder to satisfy	Reduced

4.4 Defensive significance and limited ATT&CK mapping

MITRE ATT&CK mapping is necessarily narrow because this CVE is a transport and credential-boundary failure, not a malware family or intrusion set. The best-fit mappings are conditional and should be used to frame defensive implications rather than as proof of a specific adversary playbook.

ATT&CK ID	Technique	Rationale
T1071.001	Application Layer Protocol: Web Protocols	The vulnerable behavior is exercised through redirected network requests and proxy handling in common web protocols.
T1557	Adversary-in-the-Middle	If an attacker can induce traffic toward a proxy they control, the flaw can disclose credentials intended for a different trust boundary.

The practical security meaning is clearer than the ATT&CK fit: organizations should treat authenticated egress proxy credentials as sensitive secrets whose exposure can undermine outbound monitoring, network segregation, and downstream service trust.

5. Threat Context

CVE-2026-6253 is best understood as a trust-boundary flaw in outbound networking workflows. It does not hand an attacker code execution on the client, but it can disclose credentials that gate access to proxy infrastructure often used for inspection, segmentation, logging, or controlled internet access. In some estates, those proxy credentials effectively represent shared infrastructure access rather than a low-value convenience secret.

The issue is especially relevant in modern hybrid environments where different schemes or destinations are intentionally routed through different egress paths. For example, a development estate might send one class of traffic through an authenticated enterprise proxy while letting another class use a simpler non-authenticated path. If a redirecting endpoint can force a scheme or proxy-context transition, the second proxy may receive credentials that were never intended to cross that boundary.

5.1 Representative abuse scenarios

Scenario	Description	Defensive meaning
Redirecting artifact mirror	A compromised package or artifact endpoint returns a redirect that moves a request from one proxied path to another, exposing proxy credentials during an automated download	Review artifact trust, redirect policy, and non-human curl/libcurl usage
Multi-proxy enterprise egress	Separate internal and partner-managed proxies exist for different traffic classes; leaked credentials reach the less-trusted proxy	Treat proxy credentials as privileged secrets and rotate after exposure suspicion
Embedded library blind spot	A backup agent, updater, or deployment controller uses libcurl internally and inherits proxy definitions unknown to the owning team	Inventory embedded curl/libcurl usage, not just operator-driven CLI use
Cloud-init or bootstrap workflow	Early-instance provisioning retrieves remote resources through one proxy but follows redirects into another path before secrets are fully compartmentalized	Prioritize remediation in fleet bootstrap and image-build systems

5.2 Exploitation-status assessment

Reviewed public sources did not provide high-confidence evidence of broad in-the-wild exploitation. Public aggregation visible during this review indicated no CISA KEV listing and a low EPSS signal, while vendor and downstream advisories focused on the flaw mechanics and patch guidance rather than on active campaigns. That lowers the probability of indiscriminate internet-scale abuse, but does not reduce the business impact in environments where authenticated proxy credentials provide meaningful access or control.

6. Detection and Hunting

Detection for CVE-2026-6253 should prioritize exposure discovery, process-behavior hunting, and egress-correlation rather than classic IOC matching. The reviewed sources did not identify stable domains, hashes, or attacker infrastructure tied to the issue. The most effective strategy is to find where curl/libcurl uses authenticated proxies, follows redirects, and can cross trust boundaries between proxy definitions.

6.1 Detection coverage summary

Signal	Telemetry source	Analytic goal	Coverage caveat
Installed curl/libcurl below fixed or backported level	EDR software inventory, SBOM, package manager telemetry	Find systems needing triage or patch validation	Backports can invalidate simple version matching
`curl` / `curl.exe` executions using redirect-following plus proxy options	Process creation logs, shell audit, CI logs	Identify workflows most likely to satisfy exploit preconditions	Misses embedded libcurl use without exposed CLI flags
Use of per-scheme proxy environment variables near curl/libcurl activity	EDR env-var telemetry, CI runner config, container env inspection	Surface multi-proxy routing logic that matches the advisory conditions	Environment-variable capture is not universal
Same process contacting multiple proxies or proxy ports after an HTTP redirect	Proxy logs, network telemetry, EDR socket events	Detect potential runtime manifestations of the flaw	Requires good proxy attribution and redirect visibility
Authentication headers or credentials observed on an unexpected downstream proxy	Proxy logs, reverse-proxy headers, packet capture in tightly controlled testing	Confirm real leakage rather than mere theoretical exposure	Usually available only in lab or high-fidelity proxy environments

6.2 Sigma - curl redirect plus proxy usage

```

title: curl Redirect and Proxy Usage That May Require CVE-2026-6253 Review
id: 22d7b839-7ff6-42c4-a8db-3beff0d51f19
status: experimental
description: Detects curl or curl.exe executions that combine redirect-following and proxy configuration, which can warrant exposure review for CVE-2026-6253.
author: Lost Boys Cyber
date: 2026-06-14
references:
  - https://curl.se/docs/CVE-2026-6253.html
  - https://nvd.nist.gov/vuln/detail/CVE-2026-6253
logsource:
  category: process_creation
  product: windows
detection:
  image:
    Image|endswith:
      - '\curl.exe'
  redirect:
    CommandLine|contains:
      - ' -L '
```

```

- ' --location '
proxy_flags:
  CommandLine|contains:
    - ' --proxy '
    - ' --proxy-user '
    - ' http_proxy='
    - ' https_proxy='
    - ' all_proxy='
condition: image and redirect and proxy_flags
falsepositives:
- Legitimate automation or troubleshooting that uses redirects and authenticated proxies
- Security-team validation activity
level: medium
tags:
- attack.t1071.001
- attack.t1557

```

Linux estates should adapt the image matching to `curl` and tune field names to the local schema.

6.3 KQL - identify redirect plus proxy curl usage

```

let lookback = 30d;
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where FileName in~ ("curl", "curl.exe")
| where ProcessCommandLine has_any (" -L ", " --location ")
| where ProcessCommandLine has_any (" --proxy ", " --proxy-user ", "http_proxy=", "https_proxy=",
"all_proxy=")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessCommandLine
| order by Timestamp desc

```

6.4 KQL - curl and libcurl software inventory triage

```

DeviceTvmSoftwareInventory
| where SoftwareName has_any ("curl", "libcurl")
| project DeviceName, SoftwareName, SoftwareVersion, Vendor
| order by DeviceName asc, SoftwareName asc

```

6.5 Threat-hunting questions

Hypothesis	What to prove or disprove
Some automated workflows use redirect-following and authenticated proxy settings together	Identify `curl` or embedded libcurl usage that combines redirects with proxy credentials or per-scheme proxy env vars
Different proxies are defined for different URL schemes inside CI, build, or fleet bootstrap systems	Review runner configuration, image defaults, environment variables, and secrets distribution
Proxy credentials exposed by this flaw would materially increase attacker access	Determine whether leaked proxy credentials are shared, privileged, reusable, or scoped to high-trust egress infrastructure
Embedded libcurl use hides exposure from traditional CLI-focused hunts	Cross-reference package inventory, SBOM, and application dependency manifests with proxy-enabled software

No stable IOC set was identified from the reviewed public sources. This is a vulnerability-management and workflow-hunting problem rather than an IOC-led campaign-tracking problem.

7. Recommendations

Priority	Owner	Action	Rationale
----------	-------	--------	-----------

Immediate	Platform / endpoint engineering	Upgrade curl and libcurl to 8.20.0 or validated vendor-backported packages	Removes the vulnerable proxy-credential handling logic
Immediate	Application owners	Inventory every workflow that uses redirects with authenticated proxies, including embedded libcurl dependencies	Exposure depends on real workflow behavior, not just package presence
Immediate	IAM / network engineering	Rotate high-value proxy credentials if exposure is suspected and reduce reuse of shared proxy accounts	Limits blast radius from any prior leakage
High	CI/CD and DevOps	Review environment-variable proxy definitions and eliminate unnecessary per-scheme proxy divergence where business requirements allow	Directly reduces the advisory preconditions
High	Security engineering	Add hunts for curl redirect-plus-proxy executions and inventory detections for curl/libcurl installations	Provides the best practical visibility for this issue
High	Architecture / application engineering	Constrain redirects from untrusted sources and prefer explicit allowlists for artifact and bootstrap retrieval paths	Lowers attacker ability to induce proxy-context switching
Medium	Vulnerability management	Validate distro and appliance backports before marking systems vulnerable or remediated	Prevents false positives and false negatives in reporting
Medium	SOC / incident response	Treat proxy credentials as secrets worth containment, audit, and reuse analysis if suspicious proxy behavior is observed	Proxy compromise can undermine egress governance beyond a single host

Recommended execution order:

- Inventory curl/libcurl deployments and the workflows that use redirects plus proxy settings.
- Patch or backport affected systems, prioritizing automation, CI/CD, bootstrap, and artifact-distribution paths.
- Review and reduce multi-proxy routing where it is not strictly required.
- Hunt for redirect-plus-proxy executions and validate whether any leaked credentials would be privileged or widely reused.
- Rotate sensitive proxy credentials and tighten redirect controls where exposure is plausible.

8. References

- curl Security Advisory, `CVE-2026-6253: proxy credentials leak over redirect-to proxy` - <https://curl.se/docs/CVE-2026-6253.html>
- curl machine-readable advisory JSON - <https://curl.se/docs/CVE-2026-6253.json>
- NVD CVE record, `CVE-2026-6253` - <https://nvd.nist.gov/vuln/detail/CVE-2026-6253>
- Debian Security Tracker, `CVE-2026-6253` - <https://security-tracker.debian.org/tracker/CVE-2026-6253>

- Openwall oss-security advisory mirror - <https://seclists.org/oss-sec/2026/q2/269>
- Microsoft Security Update Guide syndication entry - <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-6253>
- OSV record, `CURL-CVE-2026-6253` - <https://osv.dev/vulnerability/CURL-CVE-2026-6253>
- OpenCVE public record, `CVE-2026-6253` - <https://app.opencve.io/cve/CVE-2026-6253>